

ClinicFlow — Business Flow and Role Integration Audit

Date: 22 September 2026

Scope: Existing ClinicFlow application; the supplied 40-section end-to-end business-logic audit request.

Method: Inspect existing code and contracts first, record a concrete mismatch, apply a targeted correction, and verify at the appropriate layer. No rebuild or replacement architecture.

A. Issues found

1. **Walk-ins stopped at Booked.** The backend checked today's session and queue rules but did not advance a walk-in into the existing waiting queue.
2. **Patient registration could create a same-clinic duplicate mobile record.** Staff had no existing-patient check or instruction to search/select the accessible record.
3. **Availability and booking disagreed after queue close.** Availability could advertise a session which booking would reject under the existing closing-time rule.
4. **QR context could outlive a valid doctor assignment.** Doctor-only QR context and subsequent reassignment were not consistently checked.
5. **Idempotent retries could change booking meaning.** The replay check did not compare clinic and booking source.
6. **Availability metadata was missing from the generated contract.** The server already returned queue mode and opening/closing times, but client types omitted them.
7. **Dependent form choices could retain invalid relationships.** Clinic, branch, doctor, and patient selections needed consistent filtering and reset behavior in booking and resource editors.
8. **Staff booking did not distinguish phone booking from walk-in.** The existing single form needed an explicit source choice, not a second booking engine.
9. **Partial QR contexts and optional context clearing were inconsistent.** A fixed doctor with an unfixed branch needed constrained continuation; clearing optional fields needed the correct nullable request values.
10. **Some operational views could retain stale state.** Dashboard freshness, patient queue selection, availability refresh, and confirmation state needed alignment with persisted server responses.
11. **Authorized existing workflows were not consistently reachable.** Administrative schedules/date exceptions and existing receptionist QR operations needed navigation aligned with backend permissions.
12. **Doctors were offered patient-registration controls they could not use.** The backend already prohibited this operation.
13. **Mobile dashboard metrics could overflow.** The browser check observed a raw fractional average-wait value widening the metric grid and clipping content.
14. **Stale server processes blocked managed startup.** Old API and frontend listeners held their configured ports even though their managed workflows showed failed.

B. Issues fixed

Issue	Targeted correction
Walk-in queue entry	Run the existing <code>checkIn</code> and <code>enqueue</code> transitions inside the appointment transaction. The same appointment, token, history, and queue rules are retained.
Same-clinic duplicate patient registration	Reject an accessible same-clinic mobile match with an instruction to search/select the existing patient. No automatic merge or global unique-mobile constraint.
Closed availability	Return the existing queue-closing restriction in availability feedback.
QR assignment validity	Validate doctor/clinic/branch relationships on save and public resolution; retain booking-time validation and revocation.
Replay mismatch	Compare clinic and source as part of the existing idempotency identity.
Contract mismatch	Add existing optional availability queue fields to OpenAPI and regenerate client/validation outputs.
Dependent selectors	Filter scoped directories and reset incompatible selections; constrain branch options to clinic and doctor options to assignments.
Phone versus walk-in	Add a minimal source choice to the shared staff booking form; phone stays Booked, eligible walk-in returns Waiting.
QR continuation	Preserve fixed context through authentication and allow only unconstrained choices; send explicit nulls when optional context is cleared.
Freshness and displayed state	Use server status/action eligibility and consistent polling/invalidation; reset stale patient queue selections.
Navigation	Expose already-authorized existing operations without adding new permission grants.
Doctor registration mismatch	Hide prohibited patient-creation controls and direct the doctor to reception/admin.
Mobile metric containment	Format displayed waiting-time precision and constrain responsive grid content; leave server calculations unchanged.
Startup	Stop only the identified stale API/frontend listeners and restart their existing managed workflows. No duplicate workflow or port redesign.

Detailed before/after evidence is in `backend-flow-audit.md` and `frontend-flow-audit.md`.

C. Existing logic preserved

- Clerk identity and account-bound roles; no role switcher or authentication bypass.
- PostgreSQL, Drizzle, the existing schema, and the current API architecture.

- One appointment record as the source of queue state; no new queue or QR appointment table.
- One booking engine for online, QR, phone, and walk-in entry points.
- Existing booking-time token allocation, doctor/branch/date token scope, unique references, and idempotency.
- Existing lifecycle: Booked → Checked In → Waiting → Called → In Consultation → Completed.
- Existing cancellation, no-show, requeue, and one-active-consultation rules.
- Check-in remains required for advance online/phone/QR bookings; only the explicitly requested walk-in behavior changes.
- Public QR links, regeneration, deactivation, image generation, and download.
- Existing mobile OTP service and explicit development-provider distinction.
- Scope enforcement on the server; frontend filtering is not treated as authorization.
- Existing responsive layout and visual design, apart from correcting observed overflow.
- No EMR, billing, prescriptions, telemedicine, AI, extra notification system, or new workflow statuses.

D. Verification performed

Static and isolated regression checks

- API-server, frontend, generated/shared libraries, and script TypeScript checks passed for the relevant implementation batches.
- Code generation succeeded after the availability-contract correction.
- Seven isolated backend service/route regression tests passed.
- Those seven tests substitute persistence and authenticated identity dependencies; they are **not** the live database or browser evidence.
- Existing API and frontend workflows were restarted and came up successfully.

Authenticated live API checks

92 passed; 0 failed; 0 skipped.

The runner used real Clerk development identities, real Bearer-authenticated HTTP requests, and the development PostgreSQL database. Business fixtures were isolated from existing records. Identity/profile linkage was provisioned for the test; clinics, branches, assignments, schedules, bookings, and transitions were exercised through actual APIs.

Verified checks included:

- Clinic/branch creation and doctor/staff assignments.
- Development mobile OTP request and verification for both test patients.
- Online booking remaining Booked before check-in.
- The same appointment being readable by its patient, assigned receptionist, doctor, Clinic Admin, and Super Admin.
- Booked → Checked In → Waiting → Called → In Consultation → Completed, with retained history.
- Persisted completion reflected in all five role dashboards.
- Walk-in immediately reaching Waiting through the same state machine.

- Future phone booking remaining Booked; permitted cancellation and rejection of consultation after cancellation.
- QR generation/resolution, regeneration, old-reference rejection, booking, and the same completion lifecycle.
- No-show, requeue, and subsequent consultation.
- Patient queue responses containing own/aggregate data and omitting staff entries.
- Doctor-to-doctor, clinic-to-clinic, patient-to-patient, and Clinic Admin/platform access denials.
- Invalid past/closed/horizon/inactive cases, capacity limits, idempotent replay, and conflicting replay rejection.
- Concurrent Call Next serialization under the tested two-request scenario.

The exact request outcomes are retained in `api-verification.md` and `api-verification.json`. These are bounded regression checks, not a load test or security certification.

Browser verification

Browser evidence is recorded separately in `browser-verification.md`. An API success is not counted as a browser success.

Actual browser observations:

- Public landing and public QR context rendered at 390 × 844.
- Patient, Super Admin, Doctor, and Receptionist identities were established and checked against the mapped API roles. An initially unauthenticated patient test context was resolved by using a fresh isolated context; no authentication code was changed.
- An authenticated patient saw the fixed QR clinic/branch/doctor context and valid availability. An existing active fixture booking correctly caused a 409 duplicate-booking response instead of creating another record.
- After the existing fixture was completed, one new QR booking succeeded through the UI with a confirmation token and **Booked** status. It persisted after navigating to My Appointments and reloading.
- Receptionist UI actions changed that exact new appointment from **Booked** → **Checked In** → **Waiting**, retaining its token.
- The doctor UI changed the earlier audit appointment from **Called** → **In Consultation** → **Completed**. Patient reload/history and Receptionist views showed that same completed record.
- The patient queue displayed the patient's own token and aggregate progress without other patients' names/mobile numbers.
- Receptionist booking exposed Phone/advance and Walk-in choices in the same form; Clinic A offered only Branch A1 and its assigned doctor.
- Mobile controls used in the booking, confirmation, appointment, and queue checks remained usable. Wide tables intentionally have internal horizontal scrolling.
- The optional authenticated Clinic Admin settings-redirect check remained **unverified**: its test context ended at sign-in. The live API test separately confirmed that Clinic Admin cannot mutate platform settings.

The newly created QR appointment was not also run through doctor completion in the browser: that portion had already been exercised on another isolated fixture, and the API run covered the complete

lifecycle. Browser password-entry/email-delivery behavior was not tested; the browser helper established real test identities programmatically.

E. Remaining limitations and rules requiring confirmation

- Production SMS is not connected or live-delivery tested. Development mobile OTP is not evidence of phone ownership.
- Shared household numbers and cross-clinic patient matching need business confirmation. No automatic merge or global mobile uniqueness has been introduced.
- The existing OTP endpoint verifies the signed-in account's mobile. It is not an arbitrary staff-operated OTP service for another patient's phone.
- Assignment edits concurrent with booking, sustained high-contention booking traffic, and broader database/operational race scenarios are not established by the bounded checks above.
- Thirty-second polling is retained; this is near-real-time refresh, not instantaneous push.
- Existing one-session/one-break scheduling and overnight/timezone restrictions remain.
- Existing in-memory list processing, notification limitations, and Clerk-governed session lifetime remain outside this correction scope.
- Browser-authentication tooling limitations, if unresolved, must be reported as blocked verification—not silently classified as an application defect or a passing user journey.
- This audit does not establish healthcare regulatory compliance, production readiness, backup restoration, or comprehensive penetration-test coverage.

F. No-change items

The following were inspected and retained rather than replaced:

Area	Evidence / reason for no replacement
Patient entity selection	Booking already references patient profiles, not generic users. Filtering was corrected without changing the entity model.
Appointment action validation	The existing backend transition engine controls allowed actions and rejects invalid transitions; isolated and live API checks exercise it.
Server authorization	Existing role/scope checks enforce access; negative live API checks confirm the tested boundaries.
Token/reference integrity	Existing schema constraints and allocation logic remain; no second token system.
Queue privacy	Existing patient projection omits staff entries; live API privacy assertion passed, with defensive UI rendering retained.
Persisted dashboard source	Cards already use backend aggregates; freshness and numeric presentation were corrected, not the source of truth.
QR storage/model	Existing random references and ordinary appointment creation are retained.

Area	Evidence / reason for no replacement
Authentication cache isolation	Existing identity-change/sign-out cache clearing remains. Browser role-switch verification is separately qualified.
Core responsive design	Public mobile landing/QR context rendered successfully. Only observed metric overflow was targeted.

Reproduction and evidence

- Isolated backend checks: `node --test artifacts/api-server/src/backend-flow.test.mjs`
- Live integration runner: `NODE_ENV=development pnpm --filter @workspace/scripts exec tsx ./src/audit-flow.ts`
- The live runner is development/test-instance guarded and creates new isolated test fixtures. It is not a read-only command.
- Cleanup is explicit, marker-scoped, and must target only fixtures created by this runner; do not repurpose it to delete application data.
- Temporary test credentials are deliberately excluded from this report and all repository documentation.

Audit-fixture cleanup

After verification, the runner's two isolated clinic scopes and their descendants—including the browser-created appointment—were removed. All seven isolated Clerk identities were deleted and lookup-verified. The cleanup check found zero marker-owned database rows, confirmed that the original five preview accounts remain, and confirmed that the temporary credential file was removed. The 92-check evidence was retained. No pre-existing user records were deleted.

Backend flow audit

Pre-change findings (recorded before implementation)

Sources: full supplied end-to-end audit attachment; current backend source; docs/manual/02-backend.md, user guide, operations manual, backend interface and existing schema. The attachment supersedes the old implementation description where it explicitly changes walk-in behavior.

1. **Walk-in stays booked** (routes/appointments.ts): current validation correctly enforces today, open queue, break, capacity and mode, but all sources finish at booked. Attachment §§12,14,16,35 require immediate queue entry for walk-ins through the same lifecycle. Correction: invoke existing checkIn and enqueue inside the same booking transaction.
2. **Staff duplicate patient creation** (routes/resources.ts): patient creation has no mobile matching guard. §11 requires existing-patient reuse. Existing manual explicitly permits non-unique mobile (households), so no global uniqueness or merge is appropriate. Correction authorized by owning agent: reject staff patient creation when mobile already exists in the same authorized clinic; return a useful search/select message, without disclosing inaccessible records.
3. **Availability advertises closed bookings** (lib/availability.ts): booking rejects queue-close but public availability still says available. §§7–8 require consistent availability and reasons. Correction: expose existing queue-close rule in availability, without applying walk-in-only queue-open/break rules to advance booking.
4. **QR assignment consistency** (routes/resources.ts, routes/public.ts): a doctor-only QR without branch does not validate doctor clinic assignment; a doctor may create a QR without their doctor ID which they then cannot read; resolution does not recheck assignment after reassignment. §§4,9 require valid context and own doctor scope. Correction: validate clinic/branch relationships on save and resolution, requiring a doctor's own context on doctor QR writes.
5. **Idempotency source mismatch** (routes/appointments.ts): replay compares patient/doctor/branch/date but not clinic/source; a retry changing advance booking to walk-in can return booked. §§7,12,37 require consistent booking semantics. Correction: include clinic and source in the existing replay identity check.
6. **Availability response contract omission** (confirmed by frontend after initial audit): existing backend returns queueMode, queueOpenTime, and queueCloseTime but OpenAPI Availability omitted them, requiring a local frontend type extension. Attachment §§7–8,26 require consistent UI/backend availability. Owning agent authorized contract reconciliation: add these existing response fields as optional metadata (times may be absent), then regenerate clients/validators. No runtime behavior changes.

Preservation / scope

No database schema, migrations, Clerk, OTP provider, token policy, status vocabulary or booking engine replacement. Generated API changes are restricted to the authorized existing availability response metadata reconciliation. Token allocation remains booking-time, monotonic across terminal rows, serialized

with existing doctor/queue advisory locks. Household mobile sharing remains possible in other registration contexts; no existing patient is merged or modified by the duplicate guard.

Fixes completed

All six pre-change findings above received the described minimal correction. Walk-in creation writes booked/check-in/waiting history and audit events using the existing transition service inside the existing transaction; a failed transition rolls back the booking on PostgreSQL. No additional appointment or queue store was introduced.

Verification actually performed

Command: `node --test artifacts/api-server/src/backend-flow.test.mjs` — **7 tests passed**. The harness bundles the real route handlers, generated validators, authorization helpers, availability logic, QR resolution and transition service. Persistence and Clerk identity lookup are isolated in-memory substitutes; time is fixed to avoid time-of-day flakiness. These are service/handler regression checks, **not live HTTP, Clerk, PostgreSQL or browser end-to-end verification**. No fixture is installed in a production path or existing database.

Covered:

- Advance booking remains booked; walk-in gets the next shared token and checked-in/waiting timestamps/history; retry returns the same appointment; source-changing idempotency replay rejects.
- Booking rejects wrong clinic scope, unassigned doctor, inactive doctor/account/clinic/branch/patient, duplicate active booking, full capacity, past date, horizon violation, closed-date exception, required mobile verification, closed queue, unopened queue, break, incompatible queue mode and future walk-in.
- Call-next selects oldest waiting entry; another active called record blocks calling; start/complete and no-show/requeue use the same record; cancellation removes normal transitions.
- Patient aggregate queue response has no `entries`, counts the active patient ahead, and rejects another patient's selected appointment. Doctor cannot read/transition another doctor's appointment; receptionist branch scope excludes other branches.
- QR booking returns a normal booked appointment; old/regenerated and inactive references reject, including old reference at final booking; removed assignment invalidates context; doctor QR writes reject missing/other doctor and clinic-unassigned doctor.
- Same-clinic accessible duplicate mobile rejects without changing existing patient; a new mobile creates normally; clinic admin cannot write masters.
- Unexpected and database conflict error responses do not include internal messages.

Command: `pnpm --filter @workspace/api-server typecheck` — **passed**.

Authorized contract follow-up: `pnpm --filter @workspace/api-spec codegen` — **passed**, including generated-library typecheck; API-server and ClinicFlow typechecks — **passed** after generation. Existing Availability `queueMode` is an optional enum (`mixed`, `appointmentsOnly`, `walkInsOnly`), and queue open/close

times are optional strings, matching the existing response's metadata without requiring schedule-only fields when absent. Generated client and Zod output were regenerated rather than hand-edited.

Reviewed and intentionally unchanged

- Authorization: Super Admin global scope; Clinic Admin assigned clinics, no administrator-role grants/master/settings writes; Receptionist assigned branch; Doctor own appointments/schedules/exceptions/QR/patient relationships; Patient own records. Public discovery exposes doctor display fields rather than private operational rows.
- Clinic admin scoped audit **read** remains existing behavior; no audit administration mutation endpoint exists. The manual explicitly documents this and the new requirement forbids platform audit administration, not explicitly scoped read.
- Availability: one active weekly session per doctor/branch/day; active assignment/account/location requirements; date exception timing/capacity overrides; booking horizon; active patient and international mobile; queue mode; duplicate active patient booking.
- One booking endpoint for all four sources; phone uses the same platform `requireMobileVerification` policy and remains booked. OTP still verifies the authenticated user's linked patient, not arbitrary staff-selected patients.
- QR random references, row lock at final booking, regeneration/deactivation, public identifiers/names-only response, and no invented expiry duration.
- Queue transition graph, booking-time monotonic token assignment, doctor plus queue advisory locks, unique token/reference/idempotency indexes and partial unique active-consultation/active-patient indexes. Call-next sorts by waiting timestamp then token; requeue gets a fresh waiting timestamp.
- Cancellation cutoff applies to staff and patients as before. No-show only from waiting/called; no-show/cancelled records do not count as waiting/completed. Estimate remains patients-ahead $\times$ (consultation + buffer), not a guarantee.
- Dashboard/report appointment metrics use scoped persisted appointments and exact statuses. Patient queue returns aggregates/own entry only. Existing dashboard entity counts and platform-local date default retained.
- Existing HTTP errors sanitize unknown/database failures; no database schema/auth changes. Availability response metadata is the only authorized contract correction.

Remaining limitations / confirmation

- No live PostgreSQL concurrency, transaction rollback, index enforcement, browser role session, Clerk login or production SMS test was performed. Advisory lock/index behavior was source-reviewed only. Parent owns integration/browser verification.
- Household members sharing a mobile are not auto-merged. The narrow staff registration guard covers accessible same-clinic records only. Global household matching, cross-clinic sharing and onboarding matching **require business-rule confirmation**; no global mobile unique constraint was added.

- Staff cannot OTP-verify an arbitrary patient through the existing authenticated-self OTP service. If policy requires verification, that patient's existing verified record is required; no new OTP mechanism was invented.
 - Patient queue lookup without appointmentId still uses the first own record for the queue (existing behavior). Clients should send appointmentId, especially when cancelled/no-show and later bookings coexist.
 - Doctor/clinic assignment or active-status edits are not uniformly serialized with booking across every resource-write route. No new global locking policy was invented; live adversarial assignment-change/booking races remain unverified.
 - Existing all-table reads/in-memory filtering and aggregate calculations remain a scaling limitation, not a correctness refactor target.
-

Frontend flow audit

Scope and evidence

Controlled changes to the existing ClinicFlow frontend; no new booking engine, queue, database model, OTP service, or layout. Read the complete supplied end-to-end audit request, existing system documentation (booking, appointment, dashboard and queue sections), backend integration notes, generated client contracts, and current resource/public/appointment/queue authorization implementations before changing the affected flows. Current code takes precedence over older documentation.

Source pointers below are relative to `artifacts/clinicflow/src` unless explicitly prefixed otherwise.

Confirmed issues and corrections

Before (confirmed by source inspection)	After	Source
Generic relation editors loaded unrelated branches and doctors; upstream assignment changes retained incompatible IDs.	Branches follow selected clinic(s); schedule/QR doctors follow clinic and branch assignments; exception branches follow the selected doctor. Invalid dependent selections are cleared after the relevant lookup completes. Multi-select blank entries are excluded from requests.	<code>resources.tsx</code> , <code>RelationInput</code> , <code>Editor</code>
Clearing optional QR doctor/branch fields omitted them from the update, retaining the old persisted context.	Nullable QR fields explicitly send null, consistent with existing <code>QrInput</code> ; generate/download/regenerate/deactivate actions remain unchanged.	<code>resources.tsx</code> , <code>resources.qrs</code> , <code>Editor</code>
Staff booking and queue lookups used public, platform-wide directories.	Staff use authenticated scoped clinic/branch/doctor endpoints; patient discovery continues to use safe public endpoints. Queue branches are restricted to selected doctor's assignments; doctors cannot switch to another doctor.	<code>clinic.tsx</code> , <code>Booking</code> , <code>Queue</code>
Staff patient dropdown loaded all readable patients, independent of selected location, with no booking-form search.	Patient entity queries include selected clinic/branch and existing name/mobile search; inactive patients are excluded. Changing location clears the selected patient. Inline registration is attached to the chosen booking location.	<code>clinic.tsx</code> , <code>Booking</code>

Before (confirmed by source inspection)	After	Source
Every non-patient booking was submitted as <code>walkIn</code> , including future visits.	Same form/service now distinguishes Phone / advance booking from Walk-in. Walk-in date follows the availability timezone, is fixed to today, and explains existing mode/open/close/break restrictions. Other bookings remain ordinary online/QR/phone bookings.	<code>clinic.tsx</code> , Booking
Confirmation always instructed check-in even when a booking was already queued.	Confirmation displays persisted status and gives booked-versus-queued guidance; links to existing appointment history. Backend worker owns walk-in <code>checkIn</code> → <code>enqueue</code> behavior.	<code>clinic.tsx</code> , booking success
Clinic+doctor QR with no branch lost its fixed doctor when an unrestricted branch changed.	Fixed doctor is retained, selectable branches follow that doctor, and only unencoded fields remain editable. QR route changes remount the form; QR validity and availability refresh every 30 seconds; an errored QR resolution no longer renders a cached booking form.	<code>clinic.tsx</code> , <code>PublicBooking</code> , Booking
Confirmation could be submitted after known unavailability; dashboard could remain stale indefinitely in another session.	Both Continue and Confirm require current compatible records and available session. Dashboard now polls persisted server data every 30 seconds, matching existing appointment/queue polling.	<code>clinic.tsx</code> , Booking, Dashboard
Patient queue date changes retained a different date's appointment; clearing the dropdown retained its queue identifiers.	Date/appointment clearing clears dependent identifiers, disables the queue request, and removes stale results. Patient appointment choices poll.	<code>clinic.tsx</code> , Queue
Call next stayed enabled for empty/active/invalid-date queues; called patients were labeled as already consulting.	Call next requires server-provided allowed <code>call</code> actions and no current token. This preserves server current-date/timezone eligibility rather than reimplementing date policy. Current token label says Called / in consultation.	<code>clinic.tsx</code> , Queue
Frontend rendered queue entries whenever returned, even for patients.	Patient view explicitly never renders staff entry rows; own entry and aggregate tokens remain. Waiting time is clearly labeled an estimate.	<code>clinic.tsx</code> , Queue
Admin schedule/exception and receptionist QR APIs existed but their routes were unreachable.	Existing modules are linked and routed for those authorized roles. Clinic-admin platform restrictions remain.	<code>App.tsx</code> , routes; <code>clinic.tsx</code> , <code>navConfig</code> ; <code>backend routes/resources.ts</code> , <code>authorizeWrite</code>
Doctor patient list and booking exposed new-patient registration despite the existing backend prohibition.	Doctor patient-list Add and booking Register actions/forms are hidden; a notice directs doctors to reception/admin for registration. Authorized staff registration remains unchanged.	<code>clinic.tsx</code> , Portal, Booking; <code>resources.tsx</code> , <code>ResourcePage</code>

Reviewed and intentionally preserved

- Appointment lists/actions already use persisted server status, server `allowedActions`, and `expectedStatus`; all mutations invalidate the shared query cache. No frontend status engine added.
- Patient booking already uses `identity.patientId`; staff selection already uses actual patient records, not generic user records.
- Public QR resolution returns location/provider context rather than patient details; booking sends the QR reference for backend revalidation. Session-storage continuation through sign-in/onboarding remains intact.
- QR creation, PNG download, opening the booking URL, regeneration confirmation and deactivation were already implemented; no print/configuration feature added.
- Existing `App.tsx` `CacheReset` listens for identity changes and clears the cache, and explicit sign-out clears it. Preserved; multi-session browser verification is still required.
- Dashboard cards already read the dashboard endpoint; no duplicate count calculation introduced.
- Existing responsive CSS already stacks important booking forms and provides scrollable tables and mobile navigation. A later parent browser pass at 390×844 (screenshot q9odwk) confirmed an unformatted average wait float expanding the dashboard grid beyond the viewport. Average wait now displays one decimal minute without changing persisted statistics. Added minimum-width containment to workspace/dashboard grid items and wrapping for KPI values/labels; no ellipsis or numeric clipping. Preserved the existing table horizontal scroll container and all layouts. This worker inspected the CSS/component and applied the correction; parent owns visual re-verification.
- Existing OTP provider/development-code messaging and API remain; no assertion that production SMS is configured or tested.
- Token issuance at booking is the existing policy; no competing token or queue implementation.

Verification actually performed

- Frontend TypeScript check: `pnpm --filter @workspace/clinicflow typecheck` passes after the implementation batch.
- Inspected related backend read scopes, resource-write permissions, assignment filtering, nullable QR contract, booking source validation, queue aggregate privacy, availability timezone/mode/open/close fields, and appointment allowed actions.
- No browser test, screenshot, workflow restart, live booking, production SMS delivery, or multi-role/session end-to-end run was performed by this worker. The parent owns the single coordinated browser verification pass. Source inspection is not runtime verification.

Contract notes and remaining verification

- Availability initially returned `queueMode`, `queueOpenTime`, and `queueCloseTime` without those fields in generated `Availability`. The backend/contract worker has now aligned the generated client. Frontend uses the generated type directly; the temporary local intersection was removed. This frontend worker did not modify spec/backend.

- Availability/queue have no `currentDate` response field. Walk-in defaults use the server-returned session timezone; queue action eligibility uses server `allowedActions`. No new endpoint or date-policy contract invented.
 - Backend owns duplicate patient-mobile matching and booking/check-in authorization. UI surfaces its errors and does not create a duplicate matching rule or bypass mobile verification. Cross-location existing-patient handling should be exercised with the backend's actual matching policy.
 - Live testing still needed: clinic/branch/doctor and multi-assignment edits; clearing optional QR context; partial QR login continuation and regenerated/deactivated references; staff phone versus today walk-in; patient selection/registration; booked → check-in → waiting → called → consultation → completed; cancellation/no-show; multi-role scope and session switching; persisted dashboard/queue refresh; mobile auth/booking/confirmation.
 - Doctor patient creation remains prohibited by the existing backend; its creation controls are now hidden with role-appropriate guidance. Receptionist/admin registration is preserved. This follow-up was inspected and typechecked, not browser-tested.
-

Authenticated API integration verification

Executed: 2026-09-22T11:18:08.586Z **Marker:** CF-AUDIT-20260922111729-42a323 **Result:** 92 passed, 0 failed, 0 skipped.

Verification evidence

Outcome	Check	Route/status	Evidence
PASS	Create isolated Clinic A through API	POST /clinics 201	Expected 201 and received 201.
PASS	Create isolated Clinic B through API	POST /clinics 201	Expected 201 and received 201.
PASS	Create Branch A through API	POST /branches 201	Expected 201 and received 201.
PASS	Create Branch B through API	POST /branches 201	Expected 201 and received 201.
PASS	Create inactive validation branch through API	POST /branches 201	Expected 201 and received 201.
PASS	Assign clinicAdmin scope through API	PATCH /users/ffa08483-49bd-459f-afe4-333c3db19efe 200	Expected 200 and received 200.
PASS	Assign receptionist scope through API	PATCH /users/f1c26a78-a6f9-47d0-9b48-1ef956e83ce2 200	Expected 200 and received 200.
PASS	Assign doctorA through doctor API	PATCH /doctors/96a3e935-d884-4833-a7ce-feac84d50c4a 200	Expected 200 and received 200.
PASS	Assign doctorB through doctor API	PATCH /doctors/6d1b164c-7121-4f8f-8ae2-e6d2cfe3410e 200	Expected 200 and received 200.
PASS	Create full-day doctorA schedule through API	POST /schedules 201	Expected 201 and received 201.
PASS	Create full-day doctorB schedule through API	POST /schedules 201	Expected 201 and received 201.
PASS	Create next-day schedule for closed-date validation	POST /schedules 201	Expected 201 and received 201.
PASS	Create future schedule for cancellation validation	POST /schedules 201	Expected 201 and received 201.
PASS	Create closed-date exception through API	POST /availability-exceptions 201	Expected 201 and received 201.
PASS	patientA request mobile OTP	POST /otp/request 200	Existing development OTP endpoint accepted request.

Outcome	Check	Route/status	Evidence
PASS	patientA development OTP delivery	POST /otp/request 200	Development provider returned an in-band code without changing global settings.
PASS	patientA verify mobile OTP	POST /otp/verify 200	Patient mobile verified via existing OTP flow.
PASS	patientB request mobile OTP	POST /otp/request 200	Existing development OTP endpoint accepted request.
PASS	patientB development OTP delivery	POST /otp/request 200	Development provider returned an in-band code without changing global settings.
PASS	patientB verify mobile OTP	POST /otp/verify 200	Patient mobile verified via existing OTP flow.
PASS	Create scoped QR through API	POST /qrs 201	Expected 201 and received 201.
PASS	Resolve active public QR without patient data	GET /public/qr/pH2j00Rnljt_UN7DiUduE5zmVKn6u57ecd2xs98P2-o 200	Expected 200 and received 200.
PASS	Regenerate QR	POST /qrs/60a7ebe2-eb42-4488-b4e6-dad231961914/regenerate 200	Expected 200 and received 200.
PASS	Reject stale regenerated QR reference	GET /public/qr/pH2j00Rnljt_UN7DiUduE5zmVKn6u57ecd2xs98P2-o 404	Expected 404 and received 404.
PASS	Resolve regenerated QR reference	GET /public/qr/3aAU6s6AirCNC5DLI6U_MhKSDRfx7YvEajwIBZC1H478 200	Expected 200 and received 200.
PASS	Patient online booking remains booked	POST /appointments 201	Expected 201 and received 201.
PASS	Online booking initial state		Advance online booking is booked, not waiting.
PASS	Idempotent booking replay	POST /appointments 201	Expected 201 and received 201.
PASS	Idempotent replay identity		Same actor/requestId returned the original appointment.
PASS	Reject idempotency key semantic mutation	POST /appointments 409	Expected 409 and received 409.
PASS	patientA sees connected appointment	GET /appointments/8a0863ba-2630-4a03-b419-cc265d58b3da 200	Expected 200 and received 200.

Outcome	Check	Route/status	Evidence
PASS	receptionist sees connected appointment	GET /appointments/8a0863ba-2630-4a03-b419-cc265d58b3da 200	Expected 200 and received 200.
PASS	doctorA sees connected appointment	GET /appointments/8a0863ba-2630-4a03-b419-cc265d58b3da 200	Expected 200 and received 200.
PASS	clinicAdmin sees connected appointment	GET /appointments/8a0863ba-2630-4a03-b419-cc265d58b3da 200	Expected 200 and received 200.
PASS	superAdmin sees connected appointment	GET /appointments/8a0863ba-2630-4a03-b419-cc265d58b3da 200	Expected 200 and received 200.
PASS	Doctor B cannot read Doctor A appointment	GET /appointments/8a0863ba-2630-4a03-b419-cc265d58b3da 403	Expected 403 and received 403.
PASS	Patient A cannot read Patient B profile	GET /patients/98f1cd7f-eacf-47a8-aaf0-8ed9a022b736 403	Expected 403 and received 403.
PASS	Clinic admin cannot mutate platform settings	PATCH /settings 403	Expected 403 and received 403.
PASS	Clinic A receptionist cannot operate Clinic B queue	POST /queue/call-next 403	Expected 403 and received 403.
PASS	checkIn 8a0863ba	POST /appointments/8a0863ba-2630-4a03-b419-cc265d58b3da/actions 200	Expected 200 and received 200.
PASS	enqueue 8a0863ba	POST /appointments/8a0863ba-2630-4a03-b419-cc265d58b3da/actions 200	Expected 200 and received 200.
PASS	Patient live queue	GET /queue? doctorId=96a3e935-d884-4833-a7ce-feac84d50c4a&branchId=f3e0c3cb-4265-428a-a703-e0cb6eb4116d&date=2026-09-22&appointmentId=8a0863ba-2630-4a03-b419-cc265d58b3da 200	Expected 200 and received 200.
PASS	Patient queue privacy		Patient response contains own/aggregate data and omits staff entries.
PASS	Call oldest waiting appointment	POST /queue/call-next 200	Expected 200 and received 200.
PASS	Call-next consistency		Call-next selected the expected waiting appointment.

Outcome	Check	Route/status	Evidence
PASS	start 8a0863ba	POST /appointments/8a0863ba-2630-4a03-b419-cc265d58b3da/actions 200	Expected 200 and received 200.
PASS	complete 8a0863ba	POST /appointments/8a0863ba-2630-4a03-b419-cc265d58b3da/actions 200	Expected 200 and received 200.
PASS	Completed appointment history remains readable	GET /appointments/8a0863ba-2630-4a03-b419-cc265d58b3da 200	Expected 200 and received 200.
PASS	Lifecycle history preserved		All connected lifecycle states persisted in order.
PASS	superAdmin dashboard reads persisted state	GET /dashboard?date=2026-09-22 200	Expected 200 and received 200.
PASS	superAdmin dashboard completion count		Completed flow is reflected in dashboard metrics.
PASS	clinicAdmin dashboard reads persisted state	GET /dashboard?date=2026-09-22 200	Expected 200 and received 200.
PASS	clinicAdmin dashboard completion count		Completed flow is reflected in dashboard metrics.
PASS	receptionist dashboard reads persisted state	GET /dashboard?date=2026-09-22 200	Expected 200 and received 200.
PASS	receptionist dashboard completion count		Completed flow is reflected in dashboard metrics.
PASS	doctorA dashboard reads persisted state	GET /dashboard?date=2026-09-22 200	Expected 200 and received 200.
PASS	doctorA dashboard completion count		Completed flow is reflected in dashboard metrics.
PASS	patientA dashboard reads persisted state	GET /dashboard?date=2026-09-22 200	Expected 200 and received 200.
PASS	patientA dashboard completion count		Completed flow is reflected in dashboard metrics.
PASS	Receptionist creates walk-in	POST /appointments 201	Expected 201 and received 201.
PASS	Walk-in immediate queue state		Walk-in traversed check-in and enqueue atomically.
PASS	noShow c939a6a5	POST /appointments/c939a6a5-1158-477d-96ed-8b4eae4d0418/actions 200	Expected 200 and received 200.

Outcome	Check	Route/status	Evidence
PASS	requeue c939a6a5	POST /appointments/c939a6a5-1158-477d-96ed-8b4eae4d0418/actions 200	Expected 200 and received 200.
PASS	Call requeued no-show	POST /queue/call-next 200	Expected 200 and received 200.
PASS	start c939a6a5	POST /appointments/c939a6a5-1158-477d-96ed-8b4eae4d0418/actions 200	Expected 200 and received 200.
PASS	complete c939a6a5	POST /appointments/c939a6a5-1158-477d-96ed-8b4eae4d0418/actions 200	Expected 200 and received 200.
PASS	Receptionist creates phone booking	POST /appointments 201	Expected 201 and received 201.
PASS	Phone advance state		Phone booking remains booked until explicit check-in.
PASS	Cancel booked appointment	POST /appointments/994988af-a501-4575-b320-bf83591f06ea/actions 200	Cancellation succeeded under configured cutoff.
PASS	Cancelled appointment rejects consultation	POST /appointments/994988af-a501-4575-b320-bf83591f06ea/actions 409	Expected 409 and received 409.
PASS	Patient books through regenerated QR	POST /appointments 201	Expected 201 and received 201.
PASS	QR converges to normal appointment		QR entry produced a standard booked appointment.
PASS	checkIn 4784e5c8	POST /appointments/4784e5c8-6038-4a73-b39f-9928f817e7ce/actions 200	Expected 200 and received 200.
PASS	enqueue 4784e5c8	POST /appointments/4784e5c8-6038-4a73-b39f-9928f817e7ce/actions 200	Expected 200 and received 200.
PASS	Call QR appointment	POST /queue/call-next 200	Expected 200 and received 200.
PASS	start 4784e5c8	POST /appointments/4784e5c8-6038-4a73-b39f-9928f817e7ce/actions 200	Expected 200 and received 200.

Outcome	Check	Route/status	Evidence
PASS	complete 4784e5c8	POST /appointments/4784e5c8-6038-4a73-b39f-9928f817e7ce/actions 200	Expected 200 and received 200.
PASS	Book sole Doctor B capacity	POST /appointments 201	Expected 201 and received 201.
PASS	Reject full session	POST /appointments 409	Expected 409 and received 409.
PASS	Closed-date availability	GET /public/availability?doctorId=96a3e935-d884-4833-a7ce-feac84d50c4a&branchId=f3e0c3cb-4265-428a-a703-e0cb6eb4116d&date=2026-09-23 200	Expected 200 and received 200.
PASS	Closed date rejected		Availability reports the configured closure.
PASS	Past availability	GET /public/availability?doctorId=96a3e935-d884-4833-a7ce-feac84d50c4a&branchId=f3e0c3cb-4265-428a-a703-e0cb6eb4116d&date=2026-09-21 200	Expected 200 and received 200.
PASS	Past date rejected		Past date is unavailable.
PASS	Booking horizon availability	GET /public/availability?doctorId=96a3e935-d884-4833-a7ce-feac84d50c4a&branchId=f3e0c3cb-4265-428a-a703-e0cb6eb4116d&date=2027-09-27 200	Expected 200 and received 200.
PASS	Beyond-horizon date rejected		Date outside configured booking horizon is unavailable.
PASS	Reject invalid doctor/branch/clinic combination	POST /appointments 403	Expected 403/409 and received 403.
PASS	Reject inactive or unassigned branch	POST /appointments 403	Expected 403/409 and received 403.
PASS	Create race queue entry A	POST /appointments 201	Expected 201 and received 201.
PASS	Create race queue entry B	POST /appointments 201	Expected 201 and received 201.
PASS	Concurrent call-next serialization	POST /queue/call-next 409	Exactly one caller activated an appointment; the competing caller received 409.

Outcome	Check	Route/status	Evidence
PASS	Queue after call-next race	GET /queue? doctorId=96a3e935-d884-4833-a7ce-feac84d50c4a&branchId=f3e0c3cb-4265-428a-a703-e0cb6eb4116d&date=2026-09-22 200	Expected 200 and received 200.
PASS	Single active called/consultation invariant		Queue contains exactly one active called/consultation record.

Safety and retention

- All requests used genuine Clerk development-instance sessions and Bearer tokens; no auth bypass was used.
- The runner refuses non-development, non-test Clerk, and deployment environments.
- Credentials and fixture IDs exist only in `/tmp/clinicflow-audit-credentials.json` with mode 0600 and are not included here.
- Fixtures are visibly tagged and retained for the separate browser tester. Cleanup requires `--cleanup --confirm-cleanup`.
- Existing records and global settings were not changed.

Limitations

- Browser/mobile responsive checks are intentionally outside this API runner.
- Production SMS delivery is not tested; only the existing explicitly enabled development OTP provider is exercised.
- At verification time, fixtures were retained for the separate browser audit; their later confirmed cleanup is recorded below.

Post-browser cleanup

Cleanup completed after the browser audit for marker `CF-AUDIT-20260922111729-42a323`. The prior **92 passed, 0 failed, 0 skipped** verification result above is preserved.

- Cleanup revalidated that both fixture clinics were marker-tagged and owned by one of the isolated runner accounts before deleting anything.
- Appointment discovery used the two verified fixture clinic scopes rather than only the IDs recorded by the runner. This included the browser-created QR appointment and every other appointment descendant in those isolated scopes.
- Related appointment history, OTP challenges, availability exceptions, schedules, QR records, audit records, assignments, scoped patient descendants, fixture doctor profiles, branches, clinics, and the

seven isolated database accounts were removed in foreign-key-safe order.

- All seven isolated Clerk test identities were deleted and then checked by email lookup; none remained.
- A post-cleanup database query found 0 rows associated with the marker or the two fixture clinic IDs across users, clinics, branches, appointments, patients, and assignments.
- The original preview-account query still returned 5 accounts.
- `/tmp/clinicflow-audit-credentials.json` was removed and its absence was verified.

No pre-existing user, clinic, branch, appointment, patient, assignment, or original preview account was deleted.

ClinicFlow browser verification

Earlier connected checks (same coordinated audit)

- Fresh browser contexts verified real patient, Super Admin, Doctor, and Receptionist identities against `/api/me` and their mapped roles. Initial patient-session uncertainty was resolved without changing authentication code.
- Public mobile landing and fixed public QR clinic/branch/doctor context rendered at 390 × 844.
- The patient's first attempted booking correctly returned a duplicate-active-booking conflict. No duplicate appointment was created.
- Patient queue UI showed its own token and aggregate counts without another patient's name or mobile number.
- Doctor UI started and completed the existing audit appointment; the patient dashboard retained Completed after reload, and Receptionist displayed the same completed record.
- The initial mobile dashboard revealed an overflowing raw fractional average-wait value. A display-only precision/containment correction was made separately. Internal table scrolling is retained.
- Screenshot evidence identifiers: `zjtfc1` (public QR), `c3nd97` (authenticated QR), `gwtp77` (duplicate conflict), `db96ai` (patient queue), `2r0jqf` (doctor completion), `gysgn` (patient history), `zibpbj` (receptionist).

Targeted final pass

- **UI (patientA):** Reused the authenticated patient fixture context and opened the current QR reference for Clinic A / Branch A1 / doctorA on 2026-09-22. The fixed context was displayed and the form reported 15 available places.
- **UI (patientA):** Submitted exactly one booking through the QR flow. Details and review steps rendered, consent was required and checked, and confirmation succeeded with token `A23-06`, reference `CF-EA4F579FEB684C0C`, and status Booked.
- **UI (patientA):** Opened My Appointments and reloaded once. The new `A23-06` appointment persisted as Booked for Clinic A / Branch A1 / doctorA; the prior `A23-04` remained Completed.
- **UI (receptionist):** Opened the staff appointments list, located the exact new reference/token, clicked only its Check In, verified Checked In, then clicked only its Enqueue and verified Waiting with token `A23-06`. Did not call-next or complete it.
- **UI (receptionist):** Opened the receptionist booking form without submitting. Verified source options Phone / advance booking and Walk-in – today. Selecting Clinic A exposed only Branch A1; selecting Branch A1 exposed only doctorA. The form remained on step 1 and no second booking was created.
- **Optional UI (clinicAdmin):** Attempted the settings redirect check with a fresh helper context. Navigation ended at `/sign-in` rather than `/admin/settings`; no settings were changed and no further auth attempt was made.

API / non-UI

- No API suite was rerun.
- No authenticated API mutation or setup call was made in this targeted pass.
- Browser API responses were only observed indirectly through UI actions; the successful booking and lifecycle transitions were verified from rendered UI state.

Deliberate omissions

- No repeat of prior login, patient queue, doctor start/complete, or broad role checks.
- No call-next or complete action for the new A23-06 appointment.
- No additional phone/walk-in booking was submitted.
- No existing user data was canceled or otherwise altered.

Responsive note

At 390x844, the appointment table is intentionally internally scrollable but its columns wrap/clip until scrolled. The targeted booking, check-in, and enqueue controls remained accessible and rendered without modal or error overlap.